



POLICY – TEMPLATE

Access Control and Password Policy

Document Control

Version Control

Date	Version	Details	Author

Approval

Delegation required for approval: XXXX

Name: XXXX

Position: XXXX

Signature:

Date: XXXXX

N.B. ASSOCIATIONS SHOULD USE THIS TEMPLATE AS GUIDANCE TO SHAPE THE POLICY, WHICH IS MEANINGFUL AND FIT FOR PURPOSE, FOR THEM.

THIS IS NOT INTENDED TO BE A ONE SIZE FITS ALL TEMPLATE.

1. Purpose and Background

The control of access to Information Assets is a fundamental part of XXXX strategy to uphold information security.

To effectively protect the confidentiality, integrity, and availability of information a comprehensive mix of physical and logical controls, which are appropriate to the business requirement, must be implemented.

2. Policy Statement

This Access Control and Password Policy is designed to take account of the business and information security requirements of the organisation and is subject to regular review to ensure that it remains appropriate.

3. Scope and Applicability

This policy applies to all XXXX personnel that use, create, deploy, or support information assets. This policy applies to all information assets and software regardless of ownership.

4. Guiding Principles

Several general principles will be used when designing access controls across XXXX services and systems. These are:

- **Defence in Depth:** security must not depend upon any single control but be the sum of a number of complementary controls.
- **Least Privilege:** the default approach taken must be to assume that access is not required, rather than to assume that it is.
- **Need to Know:** access is only granted to the information required to perform a role, and no more.
- **Need to Use:** users will only be able to access physical and logical facilities required for their role.



POLICY – TEMPLATE

Access Control and Password Policy

Adherence to these basic principles will help to keep systems secure by reducing vulnerabilities and therefore the number and severity of security incidents that occur.

5. Access Control

5.1 User access management

User Access Control procedures must be documented, implemented, and kept up to date for each application and information system to ensure authorised user access and to prevent unauthorised access. They must cover all stages of the lifecycle of user access, from the initial registration of new users to the final de-registration of users who no longer require access.

User access rights must be reviewed by XXXX at regular intervals to ensure the appropriate rights are still allocated. System administration accounts must only be provided to users that are required to perform system administration tasks.

5.2 User registration and deregistration

A request for access to the organisation's network and computer systems must first be submitted to the Business Administrator for approval.

- All requests will be processed according to a formal procedure that ensures that appropriate security checks are carried out and correct authorisation is obtained prior to user account creation.
- The principle of segregation of duties will apply so that the creation of the user account and the assignment of permissions are performed by different people.
- Each user account will have a unique username that is not shared with any other user and is associated with a specific individual i.e., not a role or job title.
- When an employee leaves the organisation under normal circumstances, their access to computer systems and data must be suspended at the close of business on the employee's last working day.
- It is the responsibility of the line manager to request the suspension of the access rights via the XXXX.

In exceptional circumstances where there is perceived to be a risk that the employee may take action that may harm the organisation prior to or upon termination, a request to remove access may be approved and actioned in advance of notice of termination being given. This precaution will especially apply in the case where the individual concerned has privileged access rights (e.g., domain admin).

User accounts must be initially suspended or disabled only and not deleted. User account names must not be reused as this may cause confusion in the event of a later investigation.

5.3 User access provisioning

- Each user must be allocated access rights and permissions to information systems and data that are commensurate with the tasks they are expected to perform. In general, this will be role-based.
- Group roles must be maintained in line with business requirements and any changes to them must be formally authorised and controlled via the change management process.
- Ad-hoc additional permissions must not be granted to user accounts outside of the group role; if such permissions are required this must be addressed as a change and formally requested.

5.4 Removal or adjustment of access rights





POLICY – TEMPLATE

Access Control and Password Policy

Where an adjustment of access rights or permissions is required (e.g., due to an individual changing role), this must be carried out as part of the role change. It must be ensured that access rights no longer required as part of the new role are removed from the user account.

If a user is taking on a new role in addition to their existing one (rather than instead of) then a new composite role must be requested via change management. Consideration of any issues of segregation of duties must be given.

Under no circumstances will administrators be permitted to change their own user accounts or permissions.

5.5 System and application access control

As part of the evaluation process for new or significantly changed systems, requirements for effective access control must be addressed and appropriate measures implemented.

These must consist of a comprehensive security model that includes support for the following:

- Creation of individual user accounts
- Definition of roles or groups to which user accounts can be assigned.
- Allocation of permissions to objects (e.g., files, programs, menus) of different types (e.g., read, write, delete, execute) to subjects (user accounts and groups)
- Provision of varying views of menu options and data according to the user account and its permission levels
- User account administration, including ability to disable and delete accounts.
- User logon controls such as:
 - Non-display of password as it is entered.
 - Account lockout once number of incorrect logon attempts exceeds a specified threshold.
 - Provide information about number of unsuccessful logons attempts and last successful logon once user has successfully logged on.
 - Date and time-based logon restrictions
 - Device and location logon restrictions
- User inactivity timeout
- Password management, including:
 - Ability for user to change password.
 - Controls over acceptable passwords
 - Password expiry
 - Hashed/encrypted password storage and transmission.
- Security auditing facilities, including logon/logoffs, unsuccessful logon attempts, object access and account administration activities.

5.6 Management of privileged access rights

Privileged access rights such as those associated with administrator-level accounts must be identified for each system or network and tightly controlled.

Access to admin level permissions must only be allocated to individuals whose roles require them and who have received enough training to understand the implications of their use.

The use of user accounts with privileged access in automated routines such as batch or interface jobs must be avoided where possible. Where this is unavoidable the password used must be protected and changed on a regular basis.

5.7 User authentication for external connections

The use of Wi-Fi on non-organisation owned PCs or devices connected to the organisation's network can seriously compromise the security of the network. Specific approval must be obtained from the Business Administrator before connecting any equipment to the organisation's network.





POLICY – TEMPLATE

Access Control and Password Policy

All third-party users, or non-XXXX owned devices requesting to connect to XXXX Wi-Fi network will be required to acknowledge and agree to the Terms & Conditions of XXXX Acceptable Use Policy prior to connection.

Partner agencies or third-party suppliers must not be given details of how to access the organisation's network. Any changes to supplier's connections (e.g., on termination of a contract) must be immediately sent to XXXX so that access can be updated or ceased.

5.8 Review of user access rights

On a regular basis (at least annually) asset and system owners must review who has access to their areas of responsibility and the level of access in place. This will be to identify:

- People who should not have access (e.g., leavers)
- User accounts with more access than required by the role.
- User accounts with incorrect role allocations
- User accounts that do not provide adequate identification, e.g., generic, or shared accounts.
- Any other issues that do not comply with this policy.

This review will be performed according to a formal procedure and any corrective actions identified and carried out. A review of user accounts with privileged access will be carried out by XXXX on a bi-annual basis to ensure that this policy is being complied with.

6. Passwords

6.1 User authentication and password policy

A strong password is an essential barrier against unauthorised access. XXXX policy is to make use of additional authentication methods based on a risk assessment which considers:

- The value of the assets protected.
- The degree of threat believed to exist.
- The cost of the additional authentication method(s)
- The ease of use and practicality of the proposed method(s)
- Any other relevant controls in place

Use of multi-factor authentication methods must be justified based on the above factors and securely implemented and maintained where appropriate.

Whether single or multi-factor authentication is used, the quality of user passwords must be enforced in all networks and systems using the following parameters:

Table 1: Passwords policy

PARAMETER	VALUE
Minimum length	8
Maximum length	16
Re-use cycle	Cannot be the same as any of the previous 12 passwords
Characters Required	At least one upper-case letter At least one lower-case letter At least one symbol At least one number
Password similarity	New password cannot share more than three characters in the same position as the old password
Change Frequency	No forced expiry
Account lockout	On five incorrect logon attempts
Account lockout action	Account must be re-enabled by the Managed Service Provider
Other controls	Password cannot contain the username.



POLICY – TEMPLATE

Access Control and Password Policy

	Password must not be on a list of common passwords e.g., Password1
--	--

The use of passphrases rather than dictionary words is encouraged.

6.2 User responsibilities

Much depends upon the degree of care exercised by the users of networks and systems in their day-to-day roles. It is vital therefore that every user plays their part in protecting the access they have been granted and ensuring that their account is not used to harm the organisation.

To maximise the security of our information every user must:

- Use a strong password (i.e., one which is in line with the rules set out in this policy)
- Never tell anyone their password or allow anyone else to use their account.
- Not record the password in writing or electronically e.g., in a file or email
- Avoid using the same password for other user accounts, either personal or business-related
- Ensure that any PC or device they leave unattended connected to the network is locked or logged out.
- Leave nothing on display that may contain access information such as login names and passwords.
- Inform the XXXX of any changes to their role and access requirements.

7. Breach of Policy

A breach of this policy may lead to disciplinary action, including but not limited to, termination of employment.

Breaches of this policy are to be reported to the relevant member of the XXXX.

8. Related Policy Documents

- Acceptable Use Policy
- Code of Conduct & Integrity

9. Review

This policy must be reviewed annually, or earlier if required.

